

# Eaton Firmware Attack Surface & Detection Brief

## Eaton Firmware Attack Surface & Detection Brief

**Scope:** 45 products / 14,461 unique hashes across 4 architecture classes. Findings combine CVE research and direct examination of the extracted firmware (services, default configs, embedded resources).

### Architecture grouping (drives the threat model, not the SKU)

| Class                                      | Products                                                                                                                                      | Stack                                                                                                                                                    | Catalog depth          |
|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
| <b>A. Modern Embedded Linux</b><br>(Yocto) | Network-M2 v3.1.15,<br>Network-M3 v2.3.3,<br>Industrial-Gateway-Card / -X2 / -M3, Rack PDU G4 v4.0.1, PXGMS, Power-Xpert-Gateway UPS/PDP Card | ARM Linux + UBIFS / RAUC, runs <code>sshd</code> / <code>snmpd</code> / <code>bacnetd</code> / <code>modbusd</code> / Lua web UI ( <code>genepi</code> ) | 3,800-5,800 hashes     |
| <b>B. ESP32 “USHA”</b>                     | BestLink, ConnectUPS, ConnectUPS-Web-SNMP-Card                                                                                                | ESP32 + flat HTML web UI, no real OS                                                                                                                     | 88-184 hashes (carved) |
| <b>C. Legacy NMC</b>                       | Network-MS (ee-he/hf/jc/jl/kb/lc/ld/le), Industrial-Modbus-Card-Mini-Slot, X-Slot-Modbus                                                      | ARM/x86 proprietary <code>NmckA</code> / <code>inmc</code> container, EOL                                                                                | 2-7 hashes (opaque)    |
| <b>D. Bare-metal UPS MCU</b>               | 5P / 5PX / 5SC / 9PX / 9SX / 9PXM / 9170+ / Blade / Ferrups                                                                                   | STM32 / Callisto chipset, .sta blocks                                                                                                                    | 6-96 hashes            |
| <b>E. PDU G3</b>                           | one SKU                                                                                                                                       | STM32 with embedded SNMP MIBs + zipped Shark web UI                                                                                                      | 14 hashes              |
| <b>F. Windows-side</b>                     | UPS Companion, IPM/IPP, RNDIS driver, PX-UPS driver, MIBs                                                                                     | Windows binaries the admin runs                                                                                                                          | small                  |

### Group A — Embedded Linux NMCs (highest blast radius)

**Direct attack surface (verified via `etc/init.d` + `/usr/sbin` in the extracted M2 rootfs):**

`sshd` · `snmpd` (v1/v2c/v3) · `bacnetd` + `bacnetmanager` · `modbusd` · `genepi` web UI · USB host

Default config files in the firmware show write-capable SNMP communities and a `superadmin` web user. The M2 also exposes BACnet (UDP/47808) and Modbus TCP (502) by default in factory state.

Confirmed CVEs:

| CVE                            | Product                                                                  | Vector                                                       | Status on the firmware you have                                               |
|--------------------------------|--------------------------------------------------------------------------|--------------------------------------------------------------|-------------------------------------------------------------------------------|
| <a href="#">CVE-2026-22613</a> | <b>Network-M3</b> firmware-upgrade MITM (insecure server identity check) | MITM during firmware update → tampered firmware              | <b>2.3.3 likely vulnerable</b> — verify; advisory says “fixed in latest”      |
| <a href="#">CVE-2025-22495</a> | <b>Network-M2</b> NTP-server-config command injection, CVSS 8.4          | Auth required, RCE via NTP field                             | <b>3.1.15 NOT vulnerable</b> (fixed in 3.0.4); but older M2 in environment IS |
| ETN-VA-2025-1009               | <b>ePDU G3</b>                                                           | (web/SNMP class; verify advisory detail)                     | depends on PDU G3 firmware version                                            |
| Bishop Fox advisory            | <a href="#">9PX 8000 SP</a>                                              | password disclosed in web UI source, CSRF on change-password | older 9PX line                                                                |

**Top attack vector (MITRE ATT&CK ICS):** [T0859 Valid Accounts](#) + [T0836 Modify Parameter](#) via SNMP `Set` or BACnet `WriteProperty`. The 2022 [CISA UPS advisory](#) explicitly called out internet-exposed Eaton/APC UPS using factory creds — the underlying class of bug is unchanged.

Group B — USHA ESP32 (older Allion-design NMCs)

The carved HTML files (we sliced 80+ per device) reveal what the device exposes: `Menu.html`, `PSnmp.html`, `PTrap.html`, `PMail.html`, `PPasswd.html`, `PWDate.html`, `PIdent.html`. So web UI manages: SNMP communities, trap targets, SMTP for alerts, password change, time sync, identity.

**Attack vectors:** - Cleartext credentials in HTTP responses (the 9PX 8000 SP “password in page source” pattern — likely also present on these older boards). - SNMP v1/v2c with default community strings (`public` / `private` baseline, Eaton historically also `Eaton`). - TFTP / unauthenticated firmware upload on `BestLink upgrade utility.exe`-style flow. - Telnet still present on older firmware revisions.

**Top vector: Unauthenticated firmware swap.** ESP32 firmware is monolithic and the BestLink-style upgrade utility flashes without verifying signatures.

Group C — Legacy NMC (NmckA / inmc / X-Slot-Modbus)

7 Network-MS variants + Industrial-Modbus + X-Slot-Modbus. All EOL, all opaque proprietary containers. The X-Slot-Modbus firmware is literal 16-bit DOS boot code (we identified the `cli; cld; xor eax,eax` prelude). These cards typically sit on management LANs in HVAC/DC facilities.

**Attack vectors:** No firmware signing, telnet+HTTP only, default community strings, Modbus TCP no-auth. These devices cannot be patched — the only defense is network isolation + detection.

### Group D — Bare-metal UPS MCU (.sta family)

The .sta blocks are flat memory segments for the UPS internal microcontrollers (Callisto chipset on 5PX G2). No network attack surface on the UPS *itself* — they reach the network only via a connected NMC.

**Attack vectors:**

- 1. **Serial/USB console** (DB9/USB-B) — direct register access if attacker is local
- 2. **Firmware tamper via setUPS.exe** running on the Windows admin host — the high-value path
- 3. **Battery-management parameter abuse** — particularly dangerous on the Li-Ion products (9PX Lithium-Ion, 5P 1U-Lithium-Ion); thermal-runaway risk if BMS protection thresholds are altered

**Top vector:** **Compromise the Windows admin host that runs setUPS.exe**, then push tampered firmware via the normal flash path. The .sta vendor SHA256s in `manifest.json` (which we now verify) can catch tampered blocks if you compare during flash.

### Group F — Windows side (the actual high-CVSS surface today)

This is where the recent CVEs are concentrated:

| CVE                            | CVSS       | Product                           | Vector                                                                                                           |
|--------------------------------|------------|-----------------------------------|------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2025-59887</a> | <b>8.6</b> | UPS Companion <3.0 (all versions) | DLL hijack RCE in installer                                                                                      |
| <a href="#">CVE-2025-59888</a> | 6.7        | UPS Companion <3.0                | Unquoted service path → SYSTEM                                                                                   |
| <a href="#">CVE-2020-6650</a>  | 7.x        | UPS Companion <1.06               | Plaintext HTTP update + <code>eval()</code> of response                                                          |
| <a href="#">IPM pre-1.69</a>   | 9.8        | Intelligent Power Manager         | <b>Unauth eval injection RCE</b> , unauth file upload, SQL injection — the highest-impact unauth on the platform |

If your admin hosts have UPS Companion <3.0 or IPM <1.69 anywhere, those are the foothold paths to the UPS infrastructure. The DLL-hijack one is especially dangerous because it triggers on installer execution.

### Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

| # | Source                               | Event                                                                                                                                                                     | What it catches                      | MITRE ATT&CK ICS           |
|---|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|----------------------------|
| 1 | <b>NMC syslog (UDP/514)</b>          | <code>login.failure</code> followed by <code>login.success</code> (different result)                                                                                      | Brute force success                  | T0812 Default Credentials  |
| 2 | NMC syslog                           | <code>firmware.upload.*</code>                                                                                                                                            | Firmware tamper attempts             | T0857 System Firmware      |
| 3 | NMC syslog                           | <code>config.change</code> + <code>user.created</code> + <code>snmp.community.modified</code>                                                                             | Persistence + parameter modification | T0836 Modify Parameter     |
| 4 | <b>Network IDS (Suricata/Zeek)</b>   | SNMP Set-Request from outside management VLAN                                                                                                                             | Direct exploitation                  | T0836                      |
| 5 | Network IDS                          | <b>Modbus function codes 5/6/15/16</b> (write coils/registers) crossing management→OT boundary                                                                            | Control-logic tamper                 | T0833 Modify Control Logic |
| 6 | Network IDS                          | BACnet <code>WriteProperty</code> to UPS/PDU NMC IPs                                                                                                                      | Building-automation pivot            | T0836                      |
| 7 | <b>Sysmon on Windows admin hosts</b> | EventID 7 (ImageLoad) on <code>setUPS*.exe</code> / <code>IPM*.exe</code> loading DLLs from non-Eaton paths                                                               | CVE-2025-59887 exploitation          | T1574.001 (Enterprise)     |
| 8 | Sysmon                               | EventID 1 (ProcessCreate) where ParentImage= <code>setUPS*.exe</code> AND child not in Eaton allow-list (e.g. <code>7z.exe</code> , <code>cmd.exe</code> from setUPS dir) | Post-exploitation of admin host      | T1059                      |

### Secondary:

- Firewall: any egress from UPS/PDU VLANs to non-RFC1918 (NMCs should never originate outbound to internet — that's the CISA 2022 warning).
- SNMP trap collector: subscribe to `upsTrapOnBattery`, `upsTrapBatteryDischarged`, `epduTrapOutletStateChange`. These are the "something is wrong with power" signals; correlate with HR/maintenance windows.
- Eaton NMC has built-in audit logging — turn on "config-change" + "session" + "alarms" categories and pipe to your SIEM via syslog. Network-M2/M3 web UI: **Settings → Management → System logs → Save & Send**.

### Power-anomaly signals (the OT-native detection):

- Sudden UPS battery-test event during business hours with no maintenance window → could be attacker confirming control

- Load drop >30% with no scheduled change → possible `Outlet Off` SNMP/BACnet write
- Output frequency drift >  $\pm 0.5\text{Hz}$  on a normally-stable UPS → control-loop tampering precursor (load oscillation attack precursor)

---

## Specific zero-day-ish concerns for your dataset

---

1. **Network-M3 firmware-upgrade MITM (CVE-2026-22613) — 2026 advisory, your firmware is 2.3.3.** Test whether 2.3.3 is the patched version. If not, the firmware-upgrade channel itself is a tamper path: an attacker on-path can swap the upgrade payload.
2. **No public CVEs against the NmckA family in the last 4 years**, despite the cards being still deployed. EOL + no scrutiny  $\neq$  no bugs — assume any input-handling code in `firmware.bin` is unaudited.
3. **USHA web UI password-disclosure pattern.** The Bishop Fox 9PX 8000 SP finding (password served in HTML source) is identical in style to USHA's flat-HTML serving model. Worth a manual audit of the carved `PPasswd.html` / `Pident.html` files we extracted to confirm whether the same bug class is present.

---

## Sources

---

- CISA — Mitigating Attacks Against UPS Devices (2022)
- Eaton PSIRT advisory index
- ETN-VA-2025-1004 — Network-M2 CVE-2025-22495
- CVE-2026-22613 — Network-M3 firmware-upgrade MITM
- CVE-2025-59887 — UPS Companion DLL hijack
- Bishop Fox — Eaton 9PX 8000 SP multiple vulnerabilities
- CISA ICS Advisory — Eaton IPM (ICSA-21-110-06)
- Eaton ePDU G3 SNMP configuration guide (default community / superadmin)
- MITRE ATT&CK for ICS — Impair Process Control (TA0106)
- CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection (2024)
- Forescout 2025 OT Threat Report — BACnet now 3rd-most-targeted protocol